LANCE

An autonomous, provable auditor for IoT/IIoT networks

Project LANCE – Université de Mons

Progress report — 23 October 2026

Work in progress: no general advantage of the model is demonstrated



The objective, and what it implies

Objective

An **autonomous and provable** auditor for IoT/IIoT networks: it explores, finds, verifies and reports, with **recomputable evidence**.

What this commits us to demonstrate

- not "the model finds more", but **under which conditions** it adds something an automation cannot;
- with **identical tools, inputs and budgets**;
- with conclusions that are **verifiable**, not plausible.

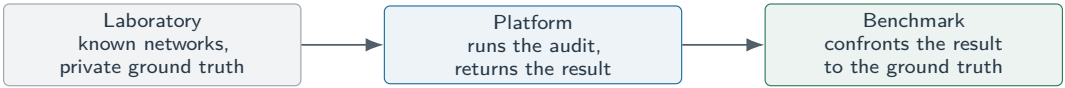
Current priorities, in order

1. the **benchmark** — the instrument that answers the question;
2. the **platform** — deploy, launch, follow, retrieve, isolate, clean up.

Out of priority

Model training. The AsiaCCS paper reports what the benchmark measures; it does not drive the order of work.

How we answer it



Three pieces, three roles

None substitutes for another. The laboratory reconstructs networks we already know; the benchmark is what turns a run into a measurement.

The model is only one piece

Probes observe, proof contracts bound what may be claimed, the engine orchestrates and accounts.

What counts as “found”

A conclusion counts only if it can be **recomputed** from what was actually observed.

Example: *“the data of another organisation can be read”*.

- × the agent *claims* it: not counted;
- ✓ the logged request and its response contain the data: counted.

We recompute the finding from the tool log. We do not re-run the requests, and we never trust the conclusion.

And the trap

The same trial runs on two configurations of the same network: one where the tested weakness is **absent**, one where it is **present**.

On the first, the correct answer is “nothing to report”. Finding something there is a **false positive**, counted as an error.

A good auditor succeeds on both

What the first campaign showed

The setup

Two network families, each with two configurations and three repetitions — the rule-based automation and the model side by side. Each arm succeeds on all six trials of each family.

Both succeed everywhere

What it means, and does not mean

- not "the model is better": there is no difference;
- not "the model is useless": this pilot was built to qualify the instrument, not to decide between the arms;
- **it cannot separate the two approaches**, and that is what we need.

The pilots show that **both instruments measure**. They do not show when a model is useful: a list of scenarios everyone passes tests no competence.

So the objective is restated as hypotheses

The objective does not change — its **form** does. "Is the model better?" cannot be settled. "*Which properties of a network make a model add something — and which do not?*" can.

#	Property of the network	What we test
H1	devices are connected	an identity link absent from public inputs
H2	formats are heterogeneous	a format the declared parsers do not cover
H3	contracts are unseen	rights and goals from never-seen documentation
H4	meaning is vendor-specific	a field whose sense is only in naming or doc
H5	devices refuse	resuming beyond the script's standard branch
H6	observed content is hostile	whether a planted instruction is obeyed

H1–H5: a possible gain

Each measures whether the model adds something.

H6: a risk, not a gain

The prediction is that a model *obeys* an injected instruction while a script ignores it. We measure the vulnerability; zero compliance is the good outcome.

What the register commits us to

Status

A **design register**. No hypothesis has been executed yet. Each one can fail — a documented failure remains a result.

Declared coverage

What is not covered is written down, not pretended: physical impact, device fragility under probing, real fleet scale.

Why this shape

- a family that tests no hypothesis does not enter the benchmark;
- a variant does not count as an independent family;
- the contrast is declared *before* the fixture;
- a null result is a result.

Before testing the model, test the test

V0 is not a hypothesis about the model

It is the **condition of interpretation** for everything else: a deliberately simple control task, solvable without inference.

Both approaches must pass

If the **script succeeds and the model fails**, the defect is in the instrument — prompt, briefing, budget, tool — not in the model's competence.

What it already caught

On one early trial the briefing documented no HTTP route: the model tried paths outside the contract and collected 404s, while the script knew where to read the policy. The defect was in the harness, not in the model.

A green run would have said nothing

The control is written and tested offline; the laboratory run on a held-out instance remains to be done.

What we can measure today

Three measurements — all **descriptive**. These are not the results of the six hypotheses.

1. Two models

Both succeed on both families. The mixture-of-experts model costs about twice as much and takes 1.3–1.7× longer, for the same result.

2. Variability

Between 6% and 46% across repetitions, setting aside one cold model load. Three repetitions give a dispersion, not a sample.

3. One discriminating case

An access-control case where the automation stops and the model does not.

The automation is **built to stop at a boundary declared in advance**; the model crosses a boundary the automation never inspects. That is **coverage**, not intelligence.

What we cannot claim

About the model

- no general advantage is demonstrated;
- no confidence interval: one family per harness, so no statistical inference — only a descriptive profile;
- no result is yet "admissible as confirmatory evidence": the metric definition is not frozen.

About the measurement

- real cost is not measured — neither billed nor hardware cost; tariff estimates are not a monetary measurement;
- "green run" $\neq$ exploitable measurement: one early run was green while every model arm had failed.

A documented null result is a usable result

Next steps, and what would help

The order follows conditions, not dates

1. **V0** on a held-out instance — MQTT as it stands; SSH only after the dictionary is randomised;
2. a **parameterisable harness** — today one scenario is a locked module;
3. **families for H2, H3, H4** — private ground truth, declared baseline, evaluator;
4. the **platform**: reproducible deployment and launch.

What would help most

- real **vendor artifacts** — H2 and H4 lack a corpus;
- an **adversarial review** of the hypothesis register, on falsifiability grounds.

Single external constraint

AsiaCCS 2027, 11 December 2026 (AoE). It does not order the steps, and justifies neither an unvalidated scope nor an unmeasured result.

Reserve — model panel

Two families, three repetitions × two configurations, two models.

Family	Approach	Success	Cost ($)
SSH	rules	6/6	0
SSH	dense model	6/6	0.006–0.008
SSH	MoE model	6/6	0.012–0.017
MQTT	rules	6/6	0
MQTT	dense model	6/6	0.004–0.010
MQTT	MoE model	6/6	0.012–0.016

Costs are tariff estimates, not billed measurements. Each family is a distinct configuration: the two are never pooled.

Reserve — variability

Coefficient of variation over three repetitions, per family and configuration.

Family / configuration	Duration	Cost	Tokens
SSH healthy	92.3%	7.0%	5.9%
SSH vulnerable	6.4%	17.9%	21.8%
MQTT healthy	27.8%	46.1%	25.6%
MQTT vulnerable	10.2%	34.7%	35.6%

The 92% figure comes from one cold model load (73.7 s against 16.6 and 16.7 s), not from policy variability.

Reserve — declared coverage gaps

- physical impact and functional safety;
- device fragility under probing;
- real fleet scale;
- proprietary industrial protocols that are not simulated;
- complete multi-step exploitation chains;
- abstention and calibration;
- generic IT scenarios, deliberately excluded.

A benchmark that states its gaps is stronger than one that claims full coverage.